

Richtlinie zum Benutzerzugangsmanagement

Datum: [Heutiges Datum]

Einleitung

Diese Richtlinie zum Benutzerzugangsmanagement definiert die Anforderungen und Maßnahmen zur Sicherstellung eines sicheren und effektiven Managements von Benutzerzugängen zu IT-Systemen und Informationen bei [Unternehmen]. Diese Richtlinie basiert auf den Standards ISO 27001:2022, ISO 27002:2022, CIS Controls v8, BSI C5:2020, der Cloud Controls Matrix (CCM), dem NIST Cybersecurity Framework 2.0, der NIS2-Richtlinie (EU 2022/2555), dem European Cyber Resilience Act (CRA) und DORA.

Geltungsbereich

Diese Richtlinie gilt für alle Mitarbeiter, Auftragnehmer, Berater, Zeitarbeitskräfte, Praktikanten und mit Dritten verbundene Personen, die Zugang zu den IT-Systemen und Informationen von [Unternehmen] haben oder für deren Verwaltung verantwortlich sind.

Compliance Matrix

Die Compliance Matrix dient dazu, die Konformität dieser Richtlinie zum Benutzerzugangsmanagement mit den relevanten Sicherheitsstandards und -richtlinien zu gewährleisten.

Komponente	ISO	TISAX	CIS	BSI	CCM	NIST	NIS2	CRA	DORA
Registrierung	9.2.1	1.1.1	6.1	ORP1	IAM01	PR.AA-01	Art.21.2	Art.10	Art.5
Zugriff	9.1.2	2.1.1	5.1	ORP3	IAM03	PR.AA-03	Art.21.2	Anh.I	Art.9
Privilegien	9.4.1	3.1.1	7.1	OPS1	IAM05	PR.AA-04	Art.21.2	Anh.I	Art.9
Review	9.5.1	4.1.1	8.1	OPS3	IVS01	DE.CM-01	Art.21.2	Anh.I	Art.9
Schulung	6.3.1	4.2.1	17.1	ORP5	STA01	GV.AT-01	Art.21.2	Anh.I	Art.5

Richtlinien und Anforderungen

Benutzerregistrierung und -abmeldung

Alle Benutzer müssen gemäß den festgelegten Verfahren registriert und abgemeldet werden (ISO 27001: 9.2.1, 9.2.2). Dies umfasst die Erstellung, Änderung und Deaktivierung von Benutzerkonten sowie die Zuweisung von Zugriffsrechten (CIS Controls 6.1, 6.2, TISAX 1.1.1, 1.2.1). Regelmäßige Überprüfungen der Benutzerkonten sind notwendig, um sicherzustellen, dass nur autorisierte Benutzer Zugriff auf die Systeme haben (BSI C5: ORP1, ORP2, CCM IAM-01, IAM-02).

Zugriffskontrollen und Authentifizierung

Der Zugang zu IT-Systemen und Informationen muss durch geeignete Zugriffskontrollen und Authentifizierungsmechanismen gesichert werden (ISO 27001: 9.1.2, 9.1.3). Dies umfasst die Implementierung von Multi-Faktor-Authentifizierung und strikten Zugangskontrollen, um unbefugten Zugriff zu verhindern (CIS Controls 5.1, 5.2, TISAX 2.1.1, 2.1.2). Regelmäßige Überprüfungen und Aktualisierungen der Zugangskontrollen sind notwendig, um die Sicherheit zu gewährleisten (NIST CSF 2.0 PR.AA-01, PR.AA-03, BSI C5: ORP3, ORP4, CCM IAM-03, IAM-04).

Verwaltung privilegierter Zugänge

Privilegierte Zugänge müssen streng verwaltet und kontrolliert werden (ISO 27001: 9.4.1, 9.4.2). Dies umfasst die Implementierung von Maßnahmen zur Verwaltung und Überwachung privilegierter Benutzerkonten, um Missbrauch zu verhindern (CIS Controls 7.1, 7.2, TISAX 3.1.1, 3.1.2). Regelmäßige Überprüfungen der privilegierten Zugänge sind notwendig, um sicherzustellen, dass sie nur für autorisierte Zwecke verwendet werden (NIST CSF 2.0 PR.AA-04, PR.AA-05, BSI C5: OPS1, OPS2, CCM IAM-05, IAM-06).

Überwachung und Überprüfung von Zugängen

Alle Benutzerzugriffe müssen kontinuierlich überwacht und regelmäßig überprüft werden (ISO 27001: 9.5.1, 9.5.2). Dies umfasst die Einrichtung von Überwachungs- und Protokollierungssystemen, um ungewöhnliche Aktivitäten zu erkennen und zu melden (CIS Controls 8.1, 8.2, TISAX 4.1.1, 4.1.2). Die Ergebnisse der Überwachung müssen dokumentiert und analysiert werden, um Verbesserungspotenziale zu identifizieren (NIST CSF 2.0 DE.CM-01, DE.CM-02, BSI C5: OPS3, OPS4, CCM IVS-01, IVS-02).

Schulung und Sensibilisierung

Alle Mitarbeiter müssen regelmäßig Schulungen zum Benutzerzugangsmanagement durchlaufen (ISO 27001: 6.3.1, 6.3.2). Diese Schulungen müssen die aktuellen Bedrohungen, Sicherheitsmaßnahmen und Best Practices abdecken (CIS Controls 17.1, 17.2, TISAX 4.2.1, 4.2.2). Sensibilisierungsmaßnahmen müssen implementiert werden, um sicherzustellen, dass alle Mitarbeiter über die aktuellen Sicherheitsanforderungen

informiert sind (NIST CSF 2.0 GV.AT-01, GV.AT-02, BSI C5: ORP5, ORP6, CCM STA-01, STA-02).

Verantwortliche

Die Implementierung und Einhaltung dieser Richtlinie liegt in der Verantwortung des IT-Sicherheitsbeauftragten und des User Access Management Teams. Alle Mitarbeiter sind verpflichtet, sich an diese Richtlinie zu halten und jegliche Verstöße umgehend zu melden.

Quellen und Referenzen

Quelle	Zweck	Link
ISO 27001:2022	Aufbau/Implementierung ISMS	Link
CIS Controls v8	Sicherheitsmaßnahmen gegen Angriffe	Link
BSI C5:2020	Cloud Security Standard	Link
CCM	Sicherheitskontrollen Cloud	Link
NIST CSF 2.0	Rahmenwerk Cybersicherheit	Link
NIS2	EU-Richtlinie Cybersicherheit	Link
CRA	EU-Verordnung Produkt-Cybersicherheit	Link
DORA	EU-Verordnung Finanzsektor	Link

Diese Quellen und Referenzen bieten umfassende Leitlinien und Best Practices für die Entwicklung und Implementierung von Sicherheitsmaßnahmen sowie für die Einhaltung der relevanten Standards und Richtlinien. Sie dienen als Grundlage und Unterstützung bei der Implementierung und Aufrechterhaltung eines effektiven Benutzerzugangsmanagements bei [Unternehmen].

Dokumentinformationen

Titel: Richtlinie zum Benutzerzugangsmanagement

Version: 1.0

Datum: [Heutiges Datum]

Verantwortlich: IT-Sicherheitsbeauftragter

Genehmigt von: [Name der genehmigenden Person]

Nächste Überprüfung: [Datum der nächsten Überprüfung]